Отчёт по лабораторной работе №3

Обнаружение и реагирование на инциденты информационной безопасности

Выполнили: Zetta

Содержание

1 Цель работы **5**

2 Легенда атаки **6**

3 Обнаружение и расследование первого этапа: GravCMS **7**
3.1 Анализ событий Security Onion 7
3.2 Анализ HTTP-запроса к GravCMS 9
3.3 Проверка состояния веб-сервера 10

4 Локализация и устранение последствий на GravCMS **13**
4.1 Ограничение доступа к административному разделу 13
4.2 Удаление подозрительного резервного файла 14

5 Обнаружение и устранение инцидента на PostgreSQL **16**
5.1 Анализ сетевого взаимодействия 16
5.2 Проверка конфигурации PostgreSQL 17
5.3 Выявление механизма закрепления 19

6 Обнаружение и реагирование на инцидент SCADA IGSS32 **22**
6.1 Обнаружение сетевой активности 22
6.2 Проверка IGSSDataServer 22
6.3 Меры реагирования на узле SCADA 23

7 Выводы **26**

8 Использованные материалы **28**

Список Иллюстраций

3.1 Общий список событий Security Onion с обнаруженными сигнатурами . . 7
3.2 Детали события Bind_API и адреса источника и назначения 8
3.3 Сигнатуры Zerologon в Security Onion 8
3.4 Подробности сигнатуры Zerologon Phase 3/3 8
3.5 События Go HTTP Client User-Agent и PHP Base64 RCE 8
3.6 Сетевые события PHP Base64 RCE: источник 195.239.174.11 и назначение 10.10.1.32:80 9
3.7 Содержимое HTTP POST-запроса к /admin/config/scheduler 10
3.8 Просмотр каталогов cron и файлов crontab на GravCMS 11
3.9 Содержимое crontab пользователя root 12
3.10 Информация об операционной системе GravCMS 12

4.1 Конфигурация Apache с ограничением доступа к /admin 13
4.2 Перезапуск Apache, просмотр соединений и завершение подозрительного процесса 14
4.3 Удаление файла evil_backup из каталога резервных копий GravCMS 15

5.1 Сетевой обмен между GravCMS и PostgreSQL на порту 5432 16
5.2 Версия PostgreSQL и расположение конфигурационных файлов 17
5.3 Правила доступа в pg_hba.conf 18
5.4 Параметр listen_addresses в postgresql.conf 19
5.5 Журнал PostgreSQL, попытки смены пароля и удаление задания cron . . . 20
5.6 Удаление evil.conf, проверка crontab и завершение процесса с внешним соединением 21

6.1 Событие Bind_API от внешнего источника к внутренним узлам, включая 10.10.3.10 22
6.2 Состояние IGSSDataServer, активный клиент и журнал запросов 23
6.3 Окно Windows Firewall с выбранным режимом On (recommended) 24
6.4 Подозрительная задача в Scheduled Tasks с периодичностью запуска раз в минуту 25

Список Таблиц

Учебный полигон Ampire. Сценарий защиты системы автоматизации процессов организации.

1 Цель работы

Изучить процесс мониторинга и расследования инцидентов информационной безопасности в учебной инфраструктуре Ampire. По событиям средств мониторинга и данным операционных систем выявить признаки компрометации веб-сервера GravCMS, сервера PostgreSQL и узла SCADA IGSS32, а также рассмотреть меры реагирования, направленные на локализацию атаки и устранение механизмов закрепления злоумышленника.

2 Легенда атаки

Согласно легенде учебного сценария, злоумышленник после разведки сети обнаружил веб-приложение организации и воспользовался уязвимостью внешнего периметра для получения доступа к серверу. Далее он попытался закрепиться в инфраструктуре и получить доступ к критически важным узлам. Задача Blue Team — выявить признаки атаки, определить затронутые узлы, зарегистрировать инциденты и устранить причины успешного выполнения атаки.

В материалах сценария выделены три основных направления:

- **GravCMS:** удалённое выполнение кода и получение доступа к веб-серверу;
- **PostgreSQL:** небезопасная конфигурация СУБД и закрепление через задание `cron`;
- **SCADA IGSS32:** эксплуатация уязвимости сервера IGSS и использование планировщика заданий.

По предоставленным журналам и сетевым событиям в работе встречаются следующие адреса:

Узел или роль	Адрес и наблюдение
Внешний источник активности	`195.239.174.11`
Веб-сервер GravCMS	`10.10.1.32`, HTTP/80
Сервер PostgreSQL	`10.10.2.26`, PostgreSQL/5432
Узел, на который направлены события Bind_API	`10.10.3.10`
Клиент, отображаемый в IGSSDataServer	`10.10.2.26:19592`

Адреса и роли приведены по имеющимся скриншотам. Наличие сетевого события само по себе не доказывает успешную эксплуатацию уязвимости: выводы ниже основаны на совокупности сетевых оповещений, содержимого пакетов и признаков на самих узлах.

3 Обнаружение и расследование первого этапа: GravCMS

3.1 Анализ событий Security Onion

В общей ленте Security Onion обнаружены события, связанные с подозрительной сетевой активностью. Среди них присутствует сигнатура `ET TROJAN Possible Metasploit Payload Common Construct Bind_API (from server)`, а также события загрузки исполняемых файлов по HTTP и сигнатуры, связанные с удалённым выполнением кода.

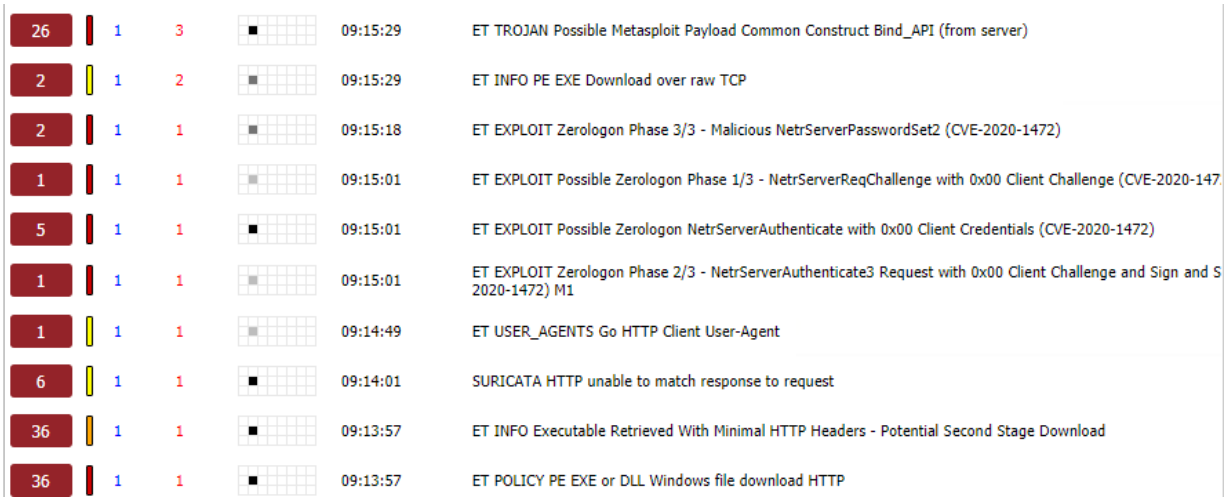


Рис. 3.1: Общий список событий Security Onion с обнаруженными сигнатурами

При раскрытии события Bind_API отображается внешний источник `195.239.174.11`. Среди адресов назначения в этом наборе событий указаны `10.10.1.253`, `10.10.2.10` и `10.10.1.26`. Данные события требуют сопоставления с журналами соответствующих узлов и не должны автоматически объединяться с каждым последующим этапом атаки.

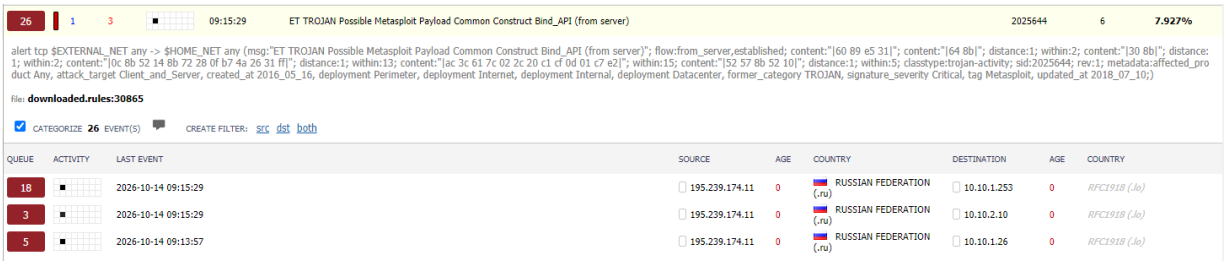


Рис. 3.2: Детали события Bind_API и адреса источника и назначения

В той же временной последовательности Security Onion отображает несколько сигнатур Zerologon, относящихся к CVE-2020-1472: запрос `NetrServerReqChallenge`, аутентификацию с нулевыми учётными данными и `NetrServerPasswordSet2`.

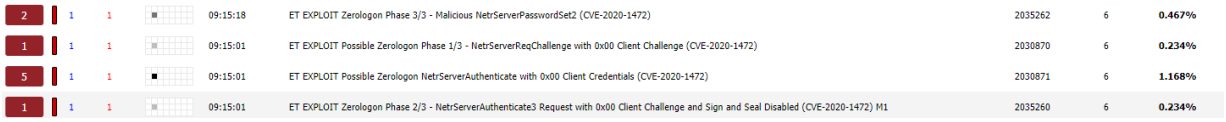
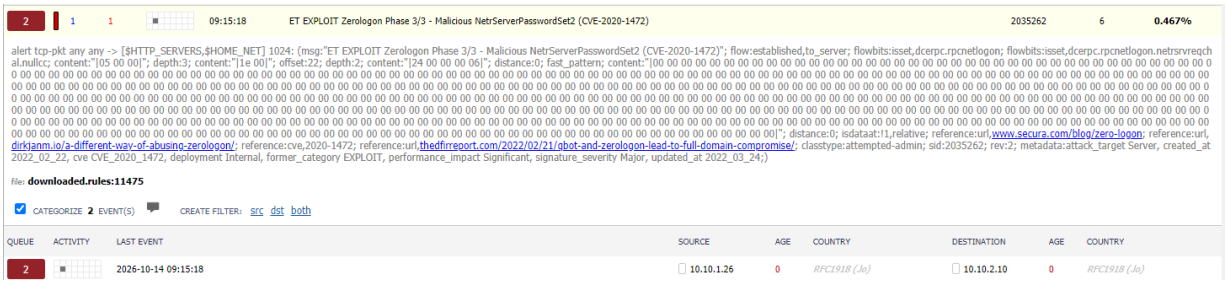
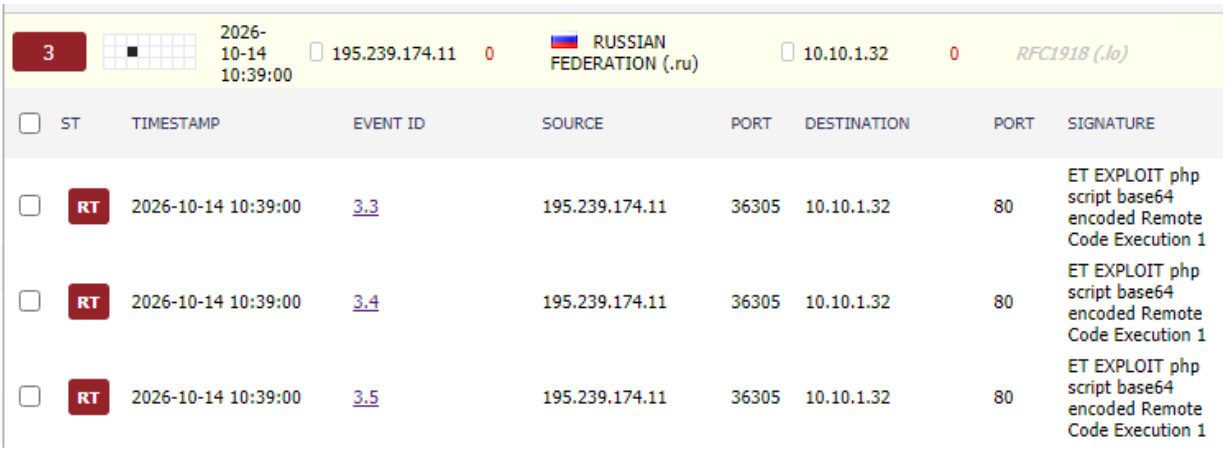


Рис. 3.3: Сигнатуры Zerologon в Security Onion

Раскрытие одной из сигнатур показывает правило обнаружения `ET EXPLOIT Zerologon Phase 3/3 - Malicious NetrServerPasswordSet2`. Эти события следует учитывать как отдельный набор индикаторов и проверять по журналам целевого узла. В основном сценарии материалов Ampire отдельно выделены GravCMS, PostgreSQL и SCADA IGSS32.


2 1 1 09:15:18 ET EXPLOIT Zerologon Phase 3/3 - Malicious NetrServerPasswordSet2 (CVE-2020-1472) 2035262 6 0.467%
alert tcp-pkt any any -> [$HTTP_SERVERS,$HOME_NET] 1024: (msg:"ET EXPLOIT Zerologon Phase 3/3 - Malicious NetrServerPasswordSet2 (CVE-2020-1472)"; flow:established,to_server; flowbits:isset,dcerpc.rpcnetlogon; flowbits:isset,dcerpc.rpcnetlogon.netrsrvreqchal.nulcc; content:"|05 00 00|"; depth:3; content:"|1e 00|"; offset:22; depth:2; content:"|24 00 00 00 06|"; distance:0; fast_pattern; content:"|00 00 00

В деталях события видны обращения с адреса `195.239.174.11` к веб-серверу `10.10.1.32` на порт TCP/80. Для нескольких записей указана сигнатура `ET EXPLOIT php script base64 encoded Remote Code Execution 1`.



3 | 2026-10-14 10:39:00 | 195.239.174.11 0 | RUSSIAN FEDERATION (.ru) | 10.10.1.32 0 | RFC1918 (.lo)

ST	TIMESTAMP	EVENT ID	SOURCE	PORT	DESTINATION	PORT	SIGNATURE
RT	2026-10-14 10:39:00	3.3	195.239.174.11	36305	10.10.1.32	80	ET EXPLOIT php script base64 encoded Remote Code Execution 1
RT	2026-10-14 10:39:00	3.4	195.239.174.11	36305	10.10.1.32	80	ET EXPLOIT php script base64 encoded Remote Code Execution 1
RT	2026-10-14 10:39:00	3.5	195.239.174.11	36305	10.10.1.32	80	ET EXPLOIT php script base64 encoded Remote Code Execution 1

Рис. 3.6: Сетевые события PHP Base64 RCE: источник 195.239.174.11 и назначение 10.10.1.32:80

3.2 Анализ HTTP-запроса к GravCMS

В сетевом дампе обнаружен HTTP-запрос:

```
POST /admin/config/scheduler HTTP/1.1
Host: 195.239.174.104
Content-Type: application/x-www-form-urlencoded
```

В теле запроса присутствуют параметры `custom_jobs` и закодированная полезная нагрузка. Ответ сервера — `HTTP/1.1 200 OK`. Это подтверждает, что веб-сервер обработал запрос и вернул успешный HTTP-статус, однако сам по себе код `200 OK` не доказывает выполнение переданного кода. В совокупности с сигнатурой RCE и последующими признаками на узле запрос рассматривается как индикатор инцидента.



Рис. 3.7: Содержимое HTTP POST-запроса к /admin/config/scheduler

3.3 Проверка состояния веб-сервера

На узле GravCMS проверено содержимое каталога `/var/spool/cron/` и каталога `crontabs`. В нём присутствуют задания для пользователей `root` и `www-data`. Наличие заданий само по себе не является признаком компрометации, поэтому далее проверено содержимое конкретного файла crontab.

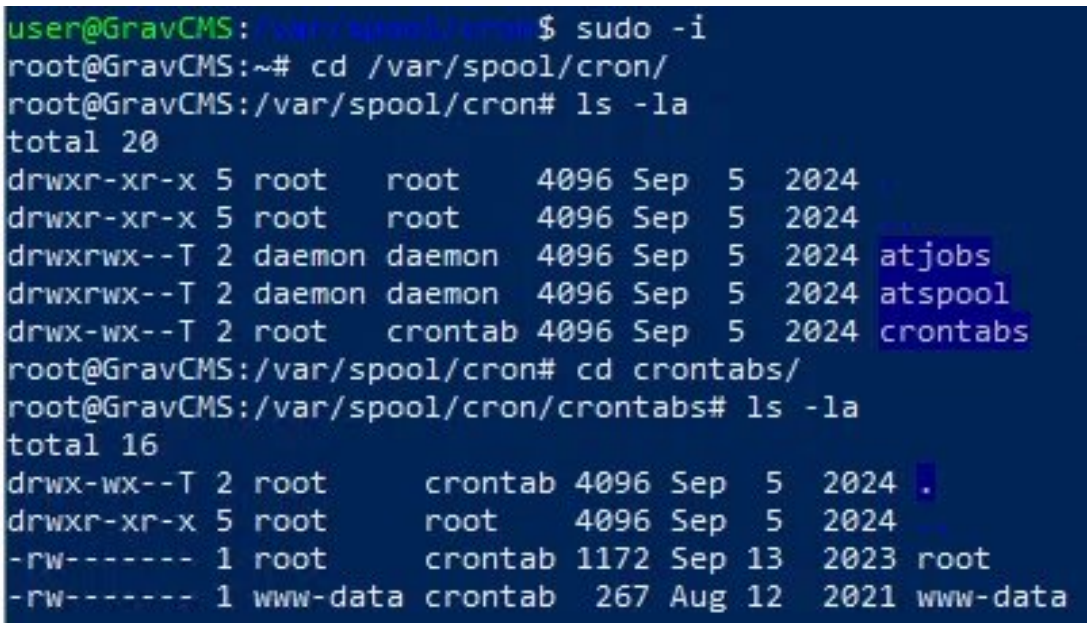


Рис. 3.8: Просмотр каталогов cron и файлов crontab на GravCMS

В crontab пользователя `root` отображается задание, запускающее архивацию каталога GravCMS с использованием шаблона `*`:

```
* * * * * tar -zcf /var/www/html/grav-admin/ && tar -zcf /var/backups/grav_backup.tar *
```

Использование подстановочного символа в команде архивации требует отдельной проверки. В материалах сценария описана уязвимость wildcard injection в связке GravCMS Admin Panel и Cron (CVE-2021-21425). Поэтому данное задание рассматривалось как потенциально опасная точка эксплуатации, а не как безусловное доказательство вредоносности обычного резервного копирования.

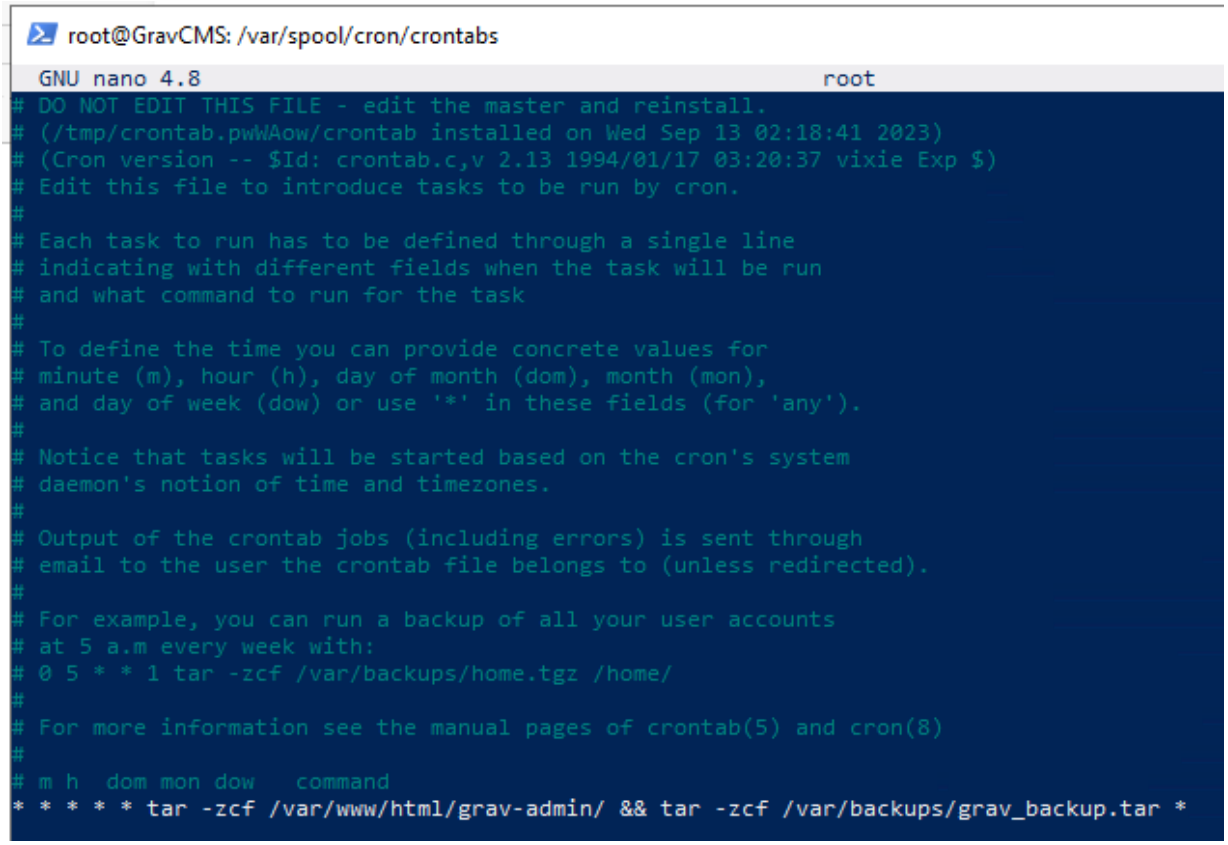


Рис. 3.9: Содержимое crontab пользователя root

Дополнительно проверена информация об операционной системе. На экране отображается Linux GravCMS с ядром `5.4.0-109-generic` (Ubuntu). Эта информация использовалась для определения конфигурации узла и выбора дальнейших действий по реагированию.

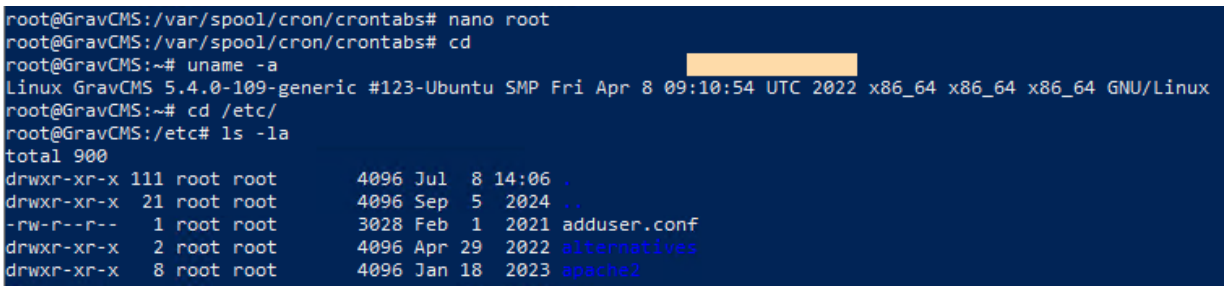


Рис. 3.10: Информация об операционной системе GravCMS

4 Локализация и устранение последствий на GravCMS

4.1 Ограничение доступа к административному разделу

В конфигурацию виртуального хоста Apache добавлено ограничение доступа к пути `/admin`:

```
<Location /admin>
    deny from all
</Location>
```

Такое правило блокирует обращения к административному разделу через данный виртуальный хост. Перед применением подобного ограничения в рабочей системе необходимо учитывать требования к легитимному административному доступу и настроить разрешённые адреса или механизм аутентификации.

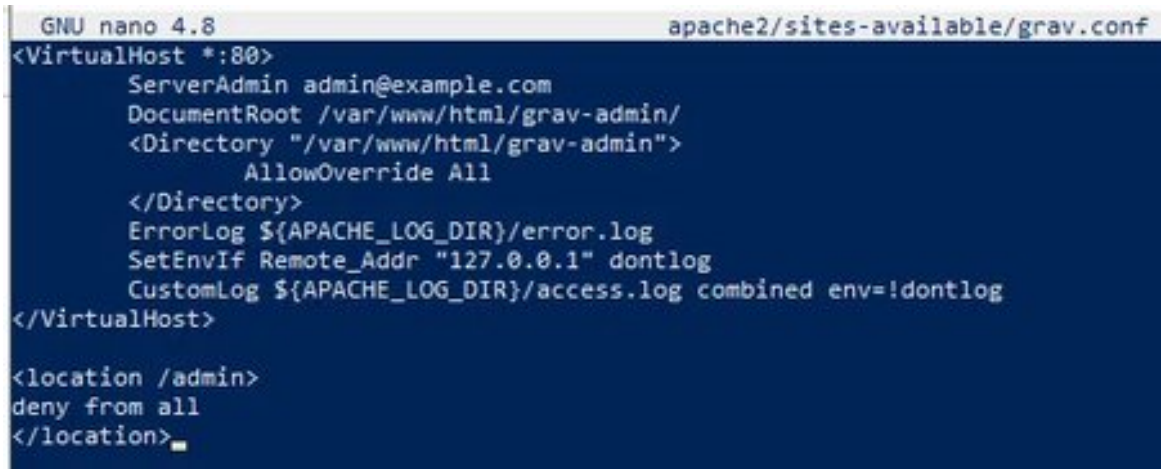


Рис. 4.1: Конфигурация Apache с ограничением доступа к /admin

После изменения конфигурации выполнен перезапуск Apache командой `systemctl restart apache2`. Затем проверены активные TCP-соединения командой `ss -tp`. Среди

соединений отображается активность процесса `chisel.sh`, связанная с внешним адресом `195.239.174.11`; в терминале показана команда завершения процесса с PID 1514.

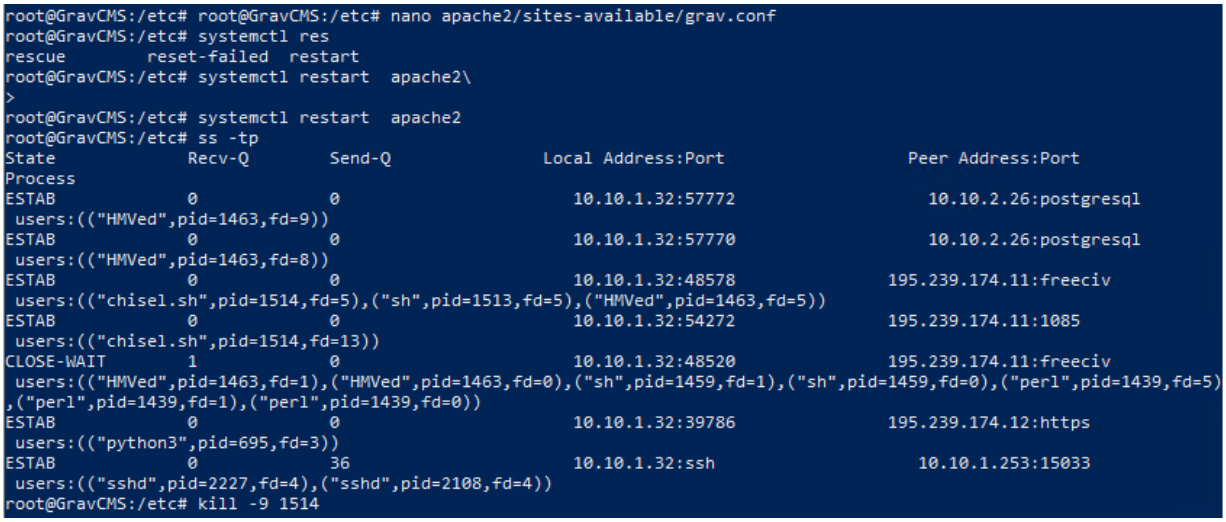


Рис. 4.2: Перезапуск Apache, просмотр соединений и завершение подозрительного процесса

4.2 Удаление подозрительного резервного файла

В каталоге резервных копий GravCMS обнаружен файл `evil_backup--20261014104001.zip`. После удаления файла повторный просмотр каталога показывает оставшуюся штатную резервную копию `default_site_backup--20221128062801.zip`.

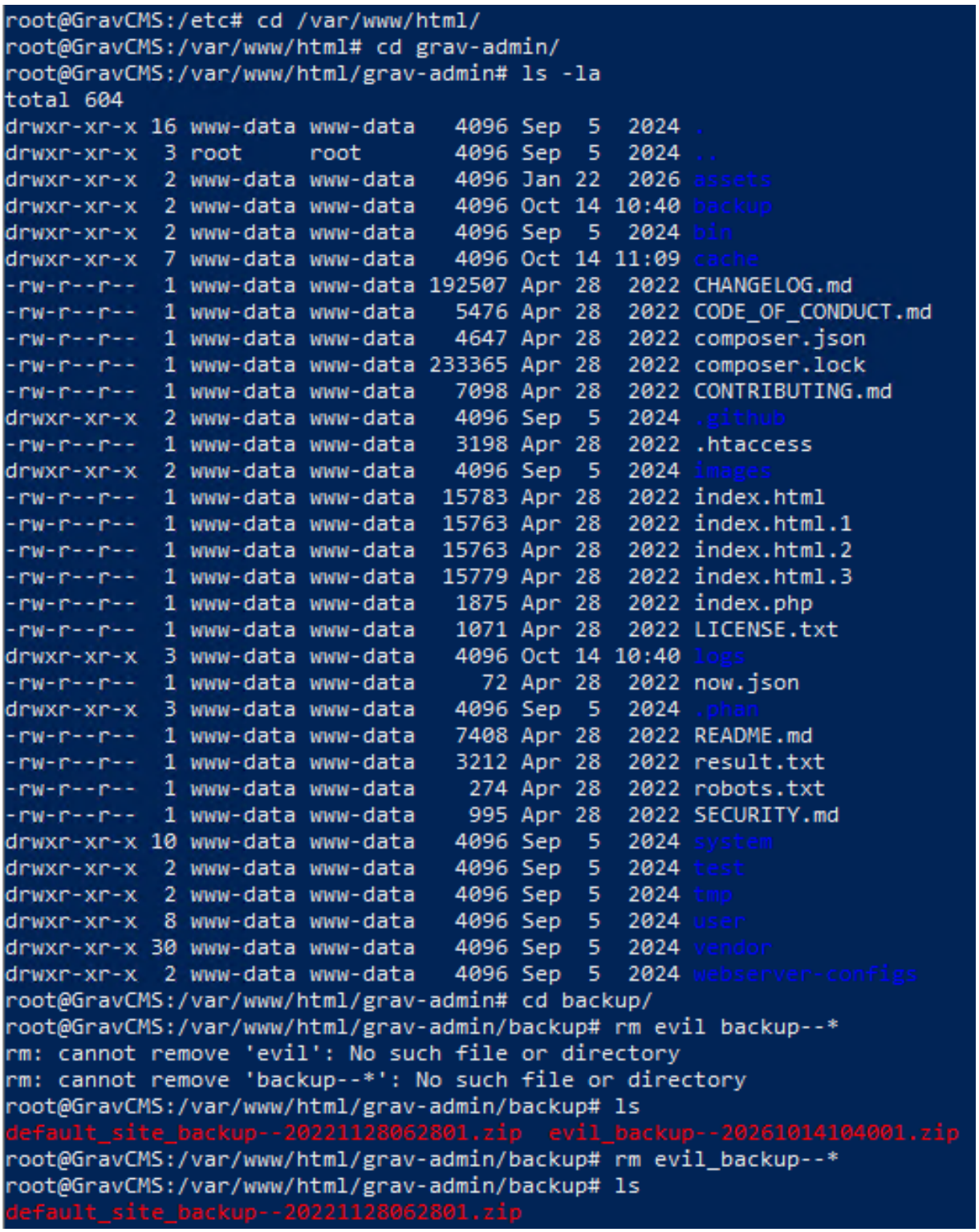


Рис. 4.3: Удаление файла evil_backup из каталога резервных копий GravCMS

Таким образом, на веб-сервере были выполнены меры по ограничению доступа к административному разделу, перезапуску Apache, завершению подозрительного процесса и удалению обнаруженного файла резервной копии. После реагирования необходимо дополнительно проверить журналы Apache, задания cron и отсутствие повторных внешних соединений.

5 Обнаружение и устранение инцидента на PostgreSQL

5.1 Анализ сетевого взаимодействия

В материалах сценария этап PostgreSQL связан с уязвимостями CVE-2019-9193 и CVE-2022-31659. В Security Onion изучен сетевой обмен между `10.10.1.32` и `10.10.2.26:5432`. В запросе присутствует обращение к базе `template1`. В ответе PostgreSQL зафиксировано сообщение:

```
FATAL: no PostgreSQL user name specified in startup packet
```

Это подтверждает попытку установления соединения с СУБД со стороны веб-сервера. Сообщение об отсутствии имени пользователя указывает на некорректный пакет запуска соединения; по нему одному нельзя сделать вывод об успешной аутентификации.

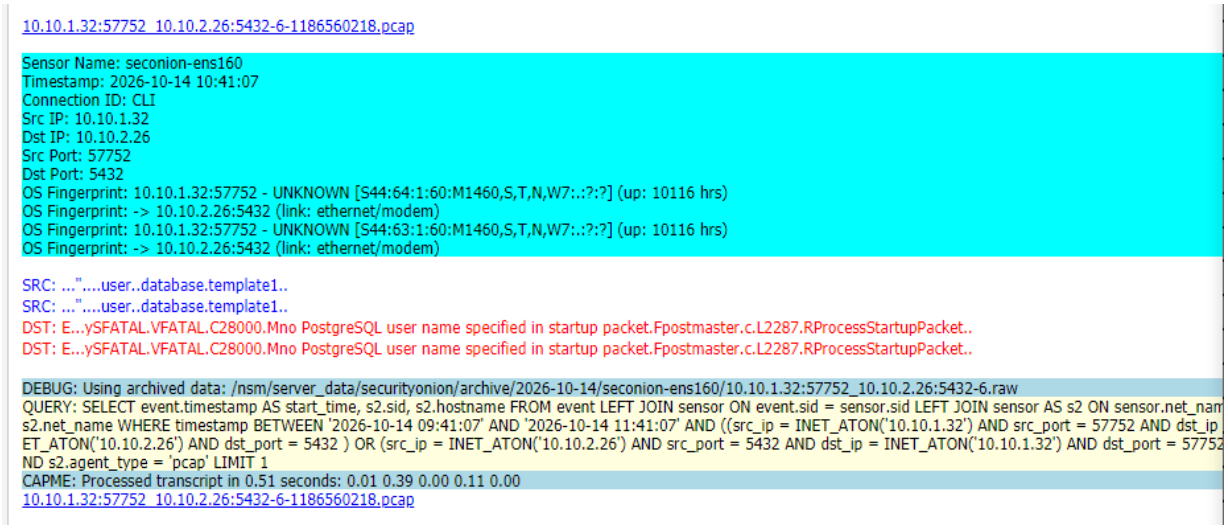


Рис. 5.1: Сетевой обмен между GravCMS и PostgreSQL на порту 5432

5.2 Проверка конфигурации PostgreSQL

На сервере 10.10.2.26 проверена версия PostgreSQL — 13.14 (Debian). Основные конфигурационные файлы находятся в каталоге /etc/postgresql/13/main/, в том числе pg_hba.conf и postgresql.conf.

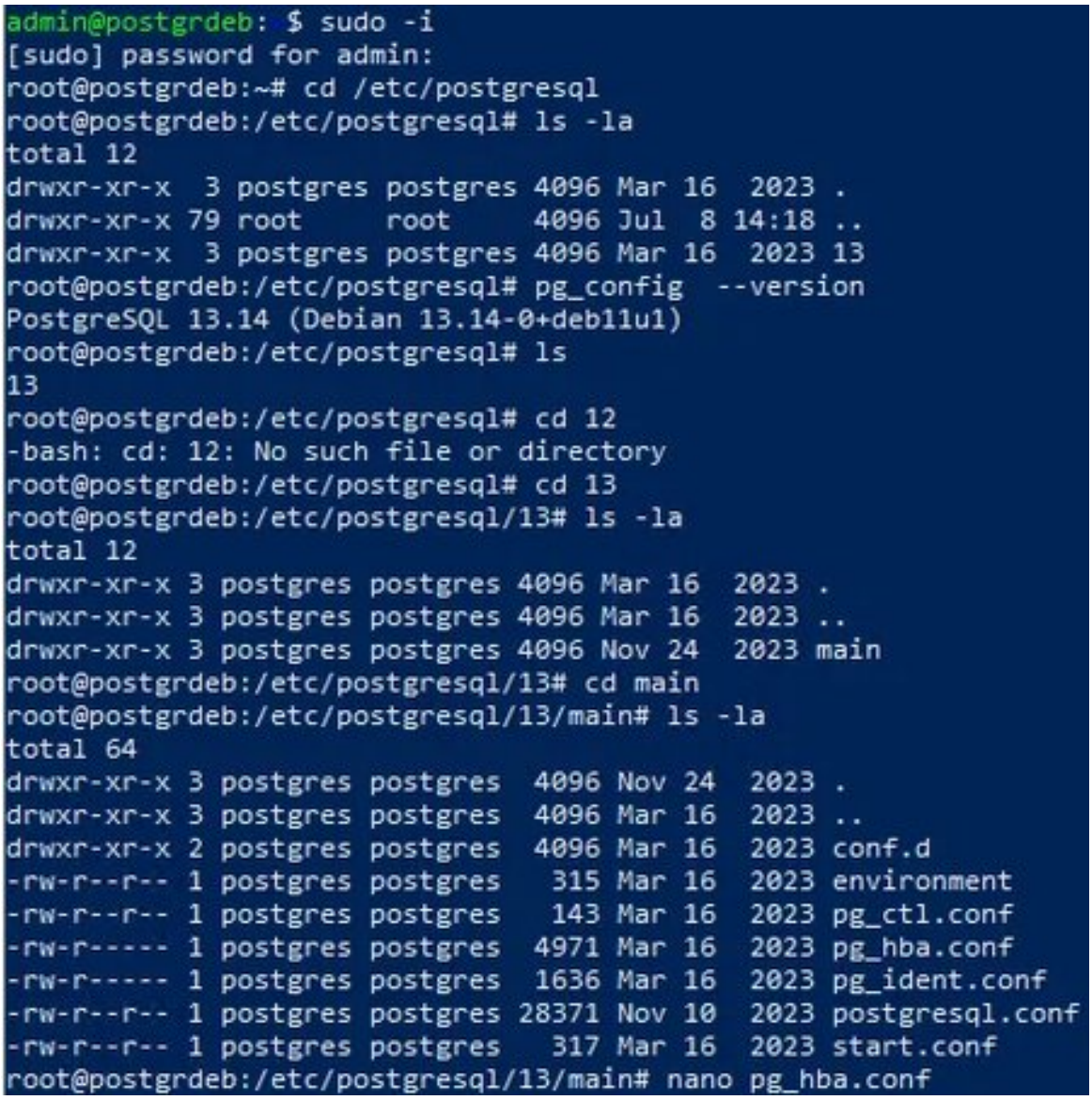


Рис. 5.2: Версия PostgreSQL и расположение конфигурационных файлов

В pg_hba.conf отображаются правила локального доступа: для Unix-сокета используется метод peer, для IPv4- и IPv6-подключений с localhost — md5. Также присутствуют правила для репликации. Данный файл определяет, какие пользователи и с каких адресов могут подключаться к СУБД и каким способом выполняется аутентификация.

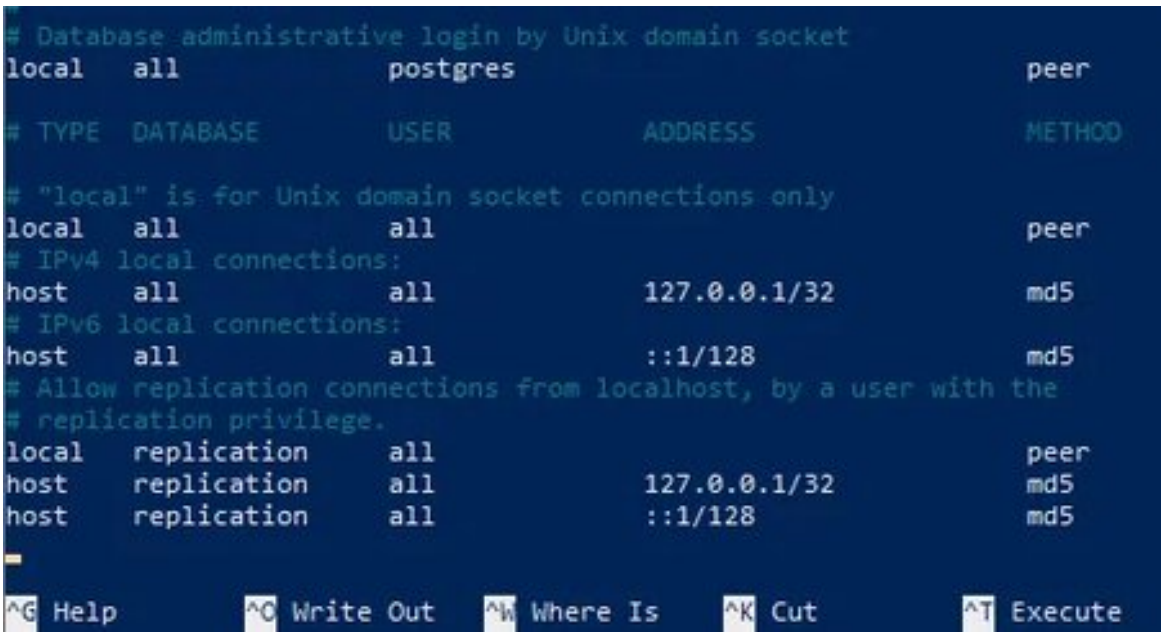


Рис. 5.3: Правила доступа в pg_hba.conf

В `postgresql.conf` обнаружен параметр:

```
listen_addresses = '*'
```

Значение `*` означает, что PostgreSQL прослушивает все доступные сетевые интерфейсы. Для сервера, которому не требуется принимать подключения со всех интерфейсов, это избыточно расширяет поверхность атаки. Следует ограничить прослушивание localhost или конкретными доверенными адресами и согласовать это ограничение с правилами `pg_hba.conf`.

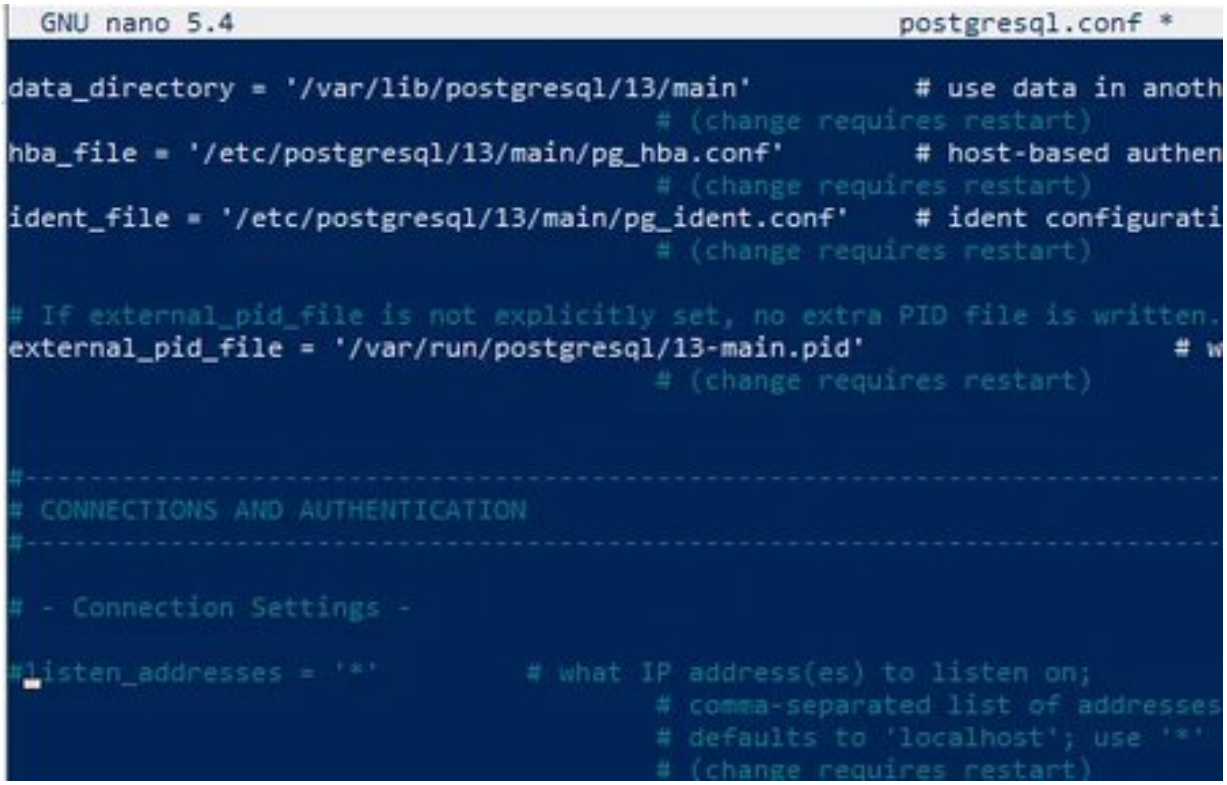


Рис. 5.4: Параметр listen_addresses в postgresql.conf

5.3 Выявление механизма закрепления

В журнале PostgreSQL обнаружены ошибки аутентификации пользователя `postgres`, в том числе сообщения `empty password returned by client` и `password authentication failed for user "postgres"`. В записи указано правило `pg_hba.conf`, по которому обрабатывалось подключение.

В ходе проверки crontab пользователя `postgres` обнаружено задание, запускаемое каждую минуту:

```
*/1 * * * * /var/lib/postgresql/evil.conf
```

Задание удалено командой `crontab -r -u postgres`; последующая проверка `crontab -l -u postgres` вернула сообщение `no crontab for postgres`. На скриншоте также зафиксирована попытка смены пароля пользователя `postgres`. Одна из попыток завершилась сообщением о несовпадении введённых значений, поэтому успешную смену пароля необходимо подтвердить отдельной проверкой.

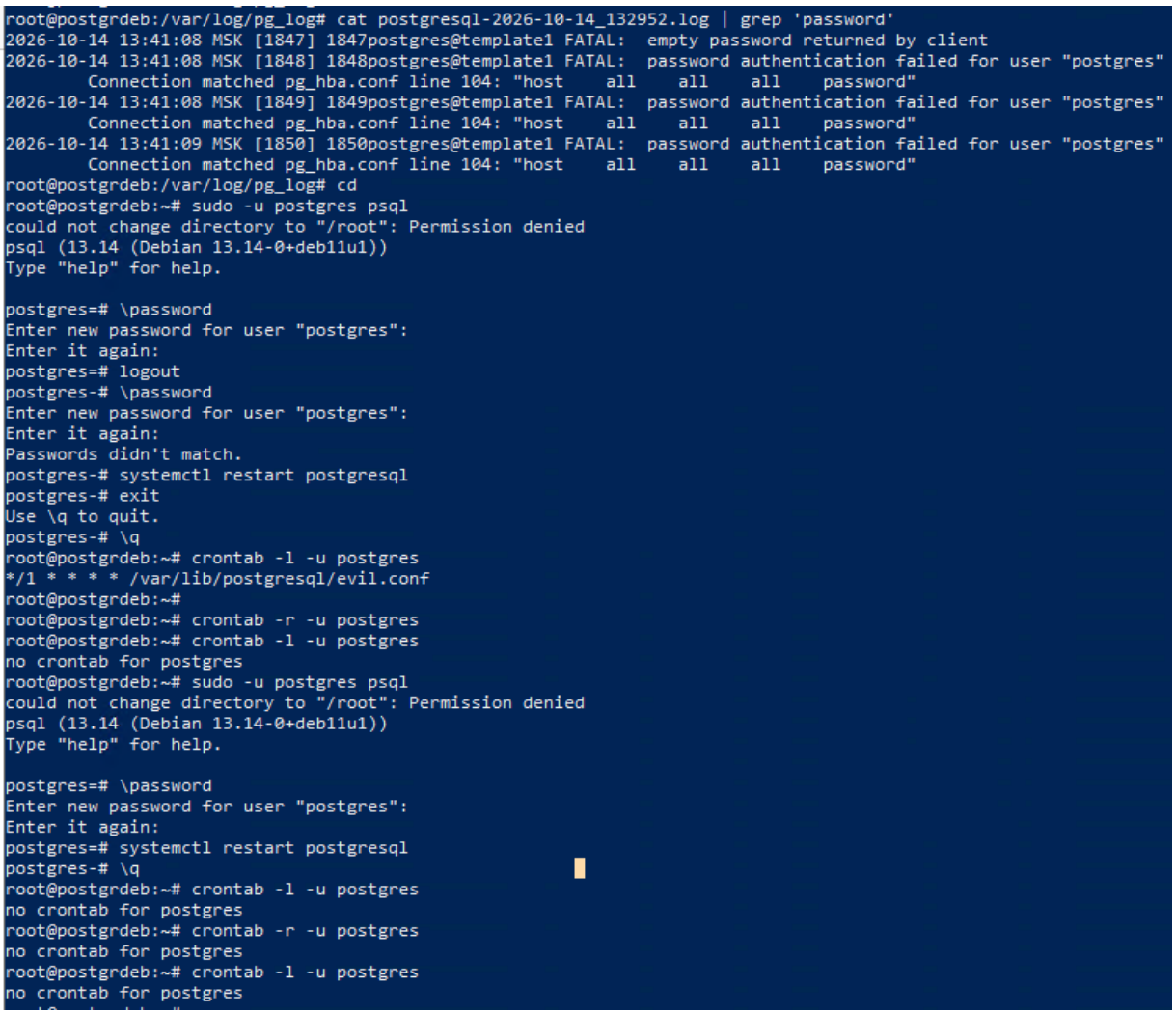


Рис. 5.5: Журнал PostgreSQL, попытки смены пароля и удаление задания cron

Дополнительная проверка показала наличие файла `/var/lib/postgresql/evil.conf` и процесса с таким именем. В выводе `ss -tp` отображалось соединение от `10.10.2.26` к внешнему адресу `195.239.174.11:7896`, связанное с процессом `evil.conf` (PID 1278). Файл удалён, задание cron повторно проверено и удалено, после чего процесс завершён командой `kill -9 1278`.

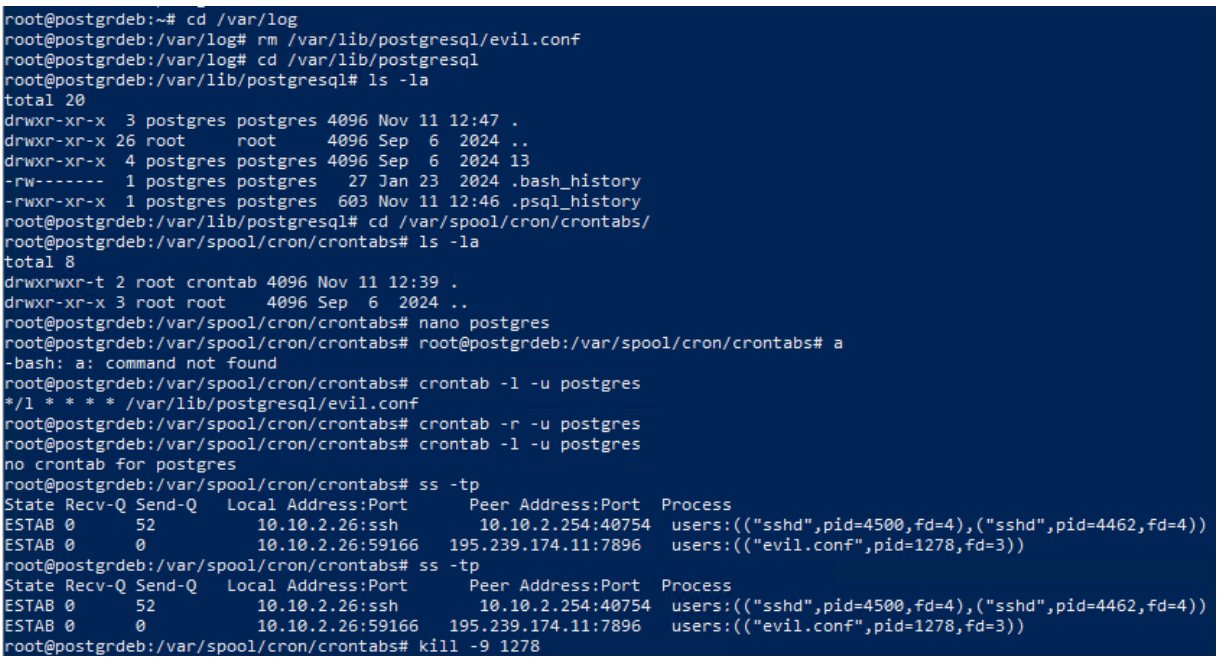


Рис. 5.6: Удаление evil.conf, проверка crontab и завершение процесса с внешним соединением

В результате были устранены обнаруженные механизмы автоматического запуска вредоносного файла: удалено задание cron пользователя `postgres`, удалён файл `evil.conf` и завершён связанный с ним процесс. Дополнительно требуется подтвердить изменение пароля и проверить фактическое значение `listen_addresses` после редактирования конфигурации и перезапуска службы.

6 Обнаружение и реагирование на инцидент SCADA IGSS32

6.1 Обнаружение сетевой активности

На следующем этапе в Security Onion обнаружено событие `ET TROJAN Possible Metasploit Payload Common Construct Bind_API (from server)`. Источник — `195.239.174.11`; среди адресов назначения присутствует узел `10.10.3.10`. Для события отображается 12 срабатываний. Данная сигнатура указывает на сетевую активность, характерную для полезной нагрузки Metasploit, и требует проверки целевого узла.

В материалах сценария для SCADA IGSS32 описана уязвимость CVE-2011-1567 — переполнение буфера в `IGSSdataServer.exe`. Сетевое событие рассматривается в контексте проверки этого этапа атаки, но само по себе не доказывает успешную эксплуатацию CVE.

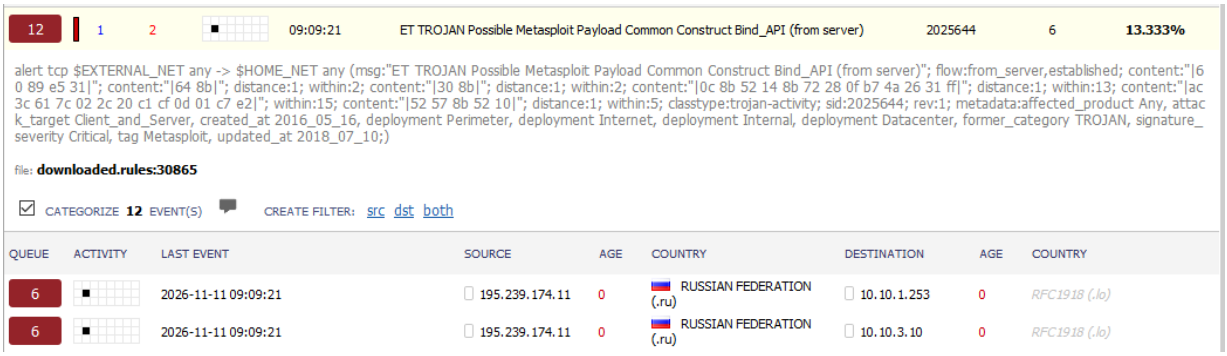


Рис. 6.1: Событие Bind_API от внешнего источника к внутренним узлам, включая 10.10.3.10

6.2 Проверка IGSSDataServer

В окне IGSSDataServer состояние сервера указано как `Running`, количество активных клиентов — 1. В списке активных клиентов отображается адрес `10.10.2.26:19592`. В

журнале присутствуют запросы `ListAll`, `Request general file` и `Request ALM`, а также записи об открытии и завершении сессий.

Это подтверждает наличие соединения узла `10.10.2.26` с сервером IGSS и активность запросов к нему. Для оценки последствий необходимо сопоставить эти записи с сетевыми событиями и временем обнаружения атаки.

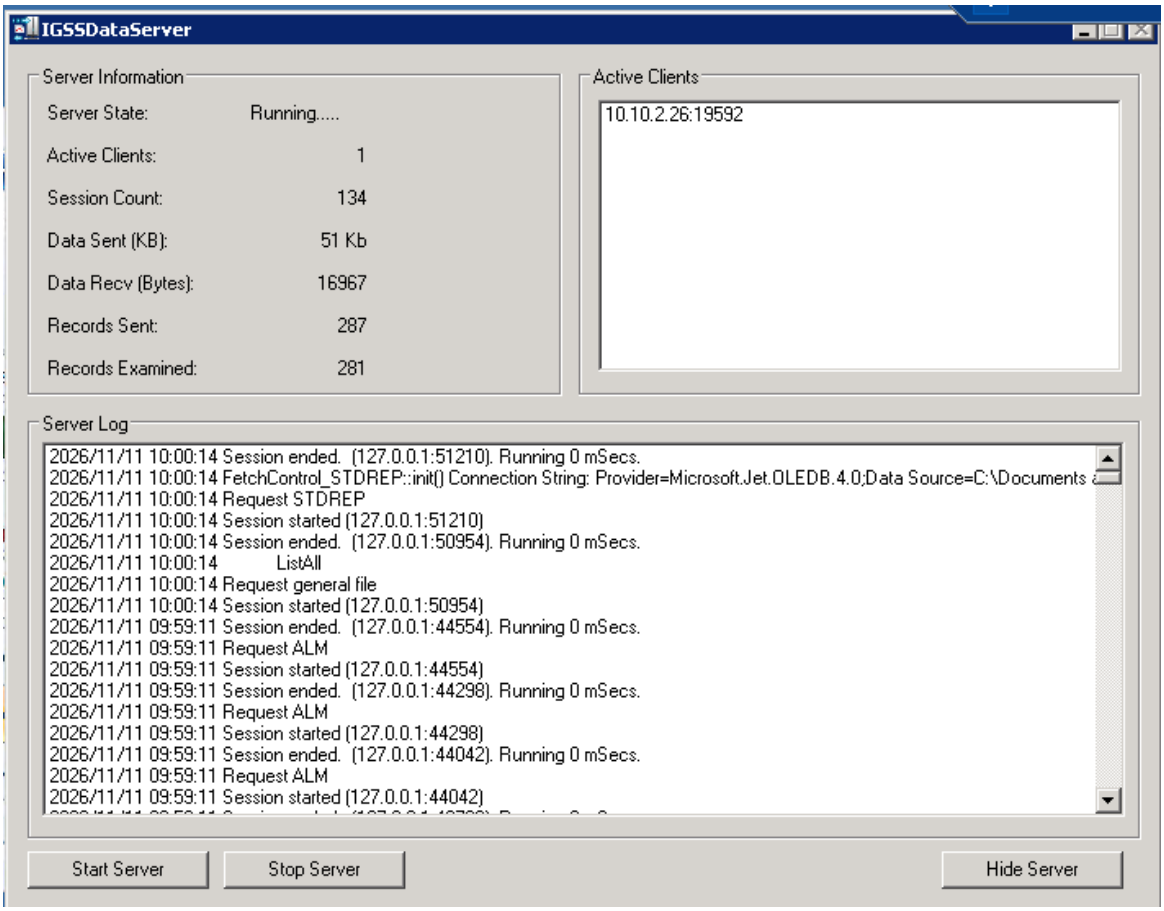


Рис. 6.2: Состояние IGSSDataServer, активный клиент и журнал запросов

6.3 Меры реагирования на узле SCADA

В интерфейсе Windows Firewall выбран режим `On (recommended)`, предназначенный для блокирования входящих подключений из внешних источников, кроме явно разрешённых исключений. На снимке при этом остаётся предупреждение `Your PC is not protected: turn on Windows Firewall`, поэтому по одному изображению нельзя подтвердить, что изменение было окончательно применено. После нажатия `OK` необходимо повторно открыть настройки и убедиться, что брандмауэр действительно включён.

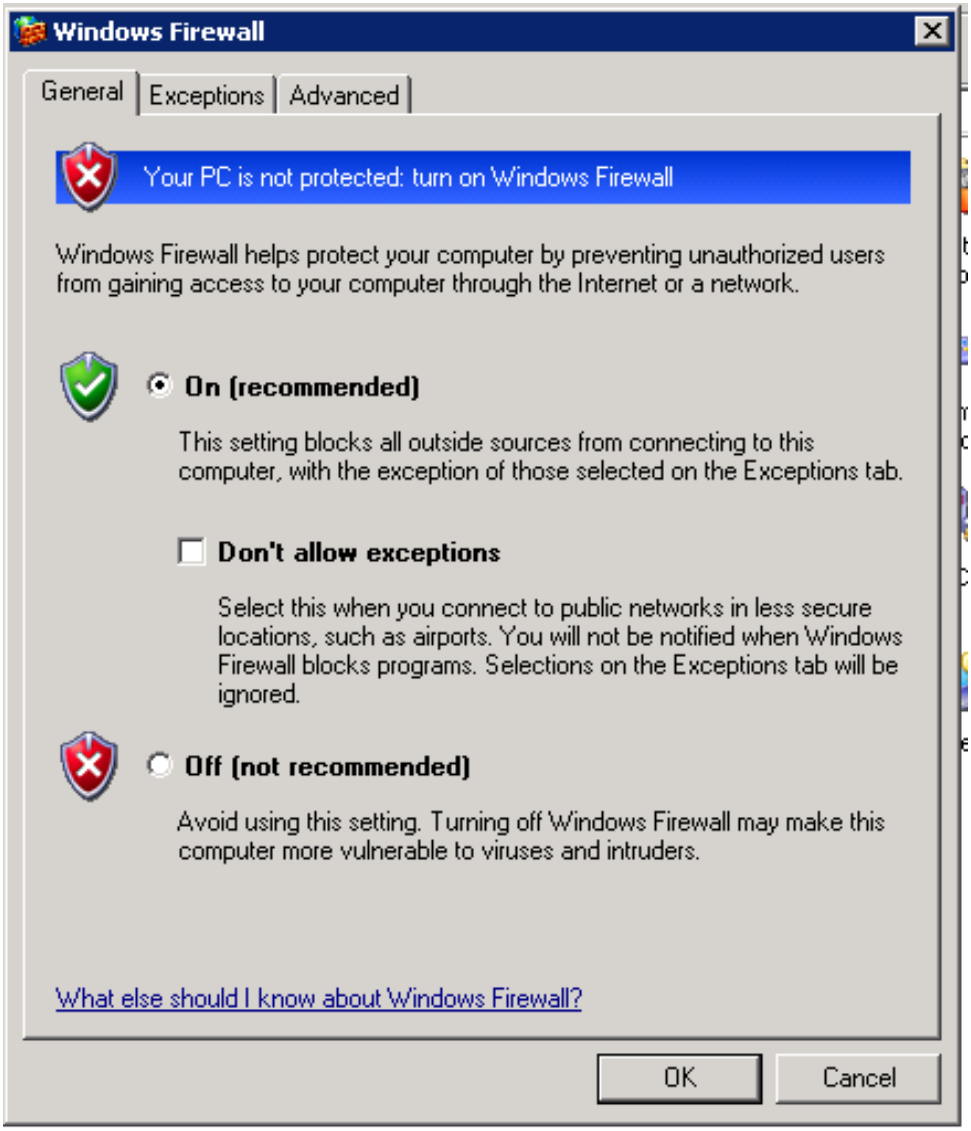


Рис. 6.3: Окно Windows Firewall с выбранным режимом On (recommended)

В оснастке Scheduled Tasks обнаружена задача с именем, начинающимся на `AM_`. В столбце Schedule указано выполнение каждую минуту, а в столбце Status — `Running`. Для задачи открыто контекстное меню и выбран пункт `Delete`. На скриншоте зафиксирован выбор удаления, но итоговое исчезновение задачи после подтверждения не показано; его необходимо проверить повторно.

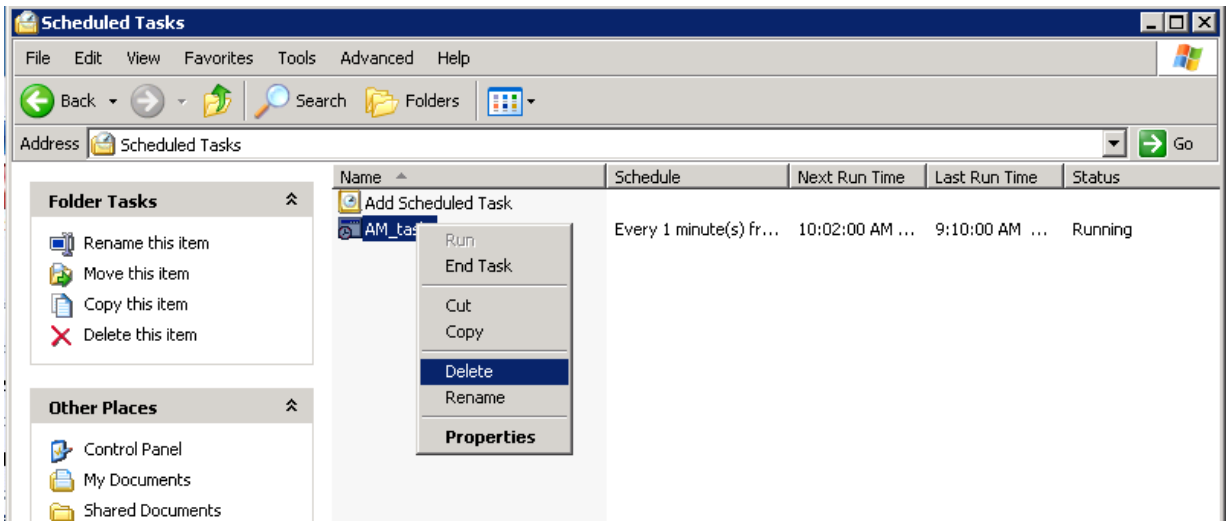


Рис. 6.4: Подозрительная задача в Scheduled Tasks с периодичностью запуска раз в минуту

7 Выводы

В ходе лабораторной работы были рассмотрены три направления атаки на учебную инфраструктуру Ampire.

- **GravCMS.** В Security Onion обнаружены события PHP Base64 RCE. В сетевом дампе выявлен POST-запрос к `/admin/config/scheduler` от внешнего адреса `195.239.174.11` к `10.10.1.32:80`. На узле проверены задания cron и активные соединения. Для реагирования ограничен доступ к `/admin`, перезапущен Apache, завершён подозрительный процесс `chisel.sh` и удалён файл `evil_backup`.
- **PostgreSQL.** Обнаружено сетевое взаимодействие `10.10.1.32` с `10.10.2.26:5432`, а в журнале СУБД — ошибки аутентификации пользователя `postgres`. Выявлены широкая настройка `listen_addresses = '*'` и задание cron, запускающее `/var/lib/postgresql/evil.conf`. Задание cron и файл удалены, связанный процесс завершён.
- **SCADA IGSS32.** Обнаружено событие Bind_API от внешнего источника к узлу `10.10.3.10`. В IGSSDataServer зафиксирован активный клиент `10.10.2.26:19592` и запросы к серверу. В Windows Firewall выбран режим включения защиты, а для подозрительной задачи Scheduled Tasks инициировано удаление.

Работа показала, что для расследования инцидента недостаточно одного срабатывания IDS: необходимо сопоставлять сетевые события с пакетами, конфигурациями, журналами и состоянием процессов на конечных узлах.

Для завершения проверки после выполненных действий необходимо подтвердить, что:

- в `postgresql.conf` ограничено значение `listen_addresses`, а служба PostgreSQL перезапущена;
- пароль пользователя `postgres` успешно изменён;
- на узле SCADA Windows Firewall действительно включён;

- подозрительная задача `AM_...` отсутствует в Scheduled Tasks;
- после очистки узлов не появляются повторные соединения с внешним адресом `195.239.174.11`.

Таким образом, в ходе работы были обнаружены признаки компрометации нескольких компонентов инфраструктуры и выполнены основные действия по удалению выявленных механизмов закрепления. Контрольная проверка конфигураций и повторный мониторинг необходимы для подтверждения полного устранения последствий инцидента.

8 Использованные материалы

1. Презентация «Киберучения на полигоне Ampire»: легенда и вектор атаки (слайды 5–7), GravCMS и CVE-2021-21425 (слайды 8–25), PostgreSQL (слайды 26–39), SCADA IGSS32 и CVE-2011-1567 (слайды 41–53).
2. Скриншоты событий Security Onion, сетевых дампов и проверки узлов, предоставленные для выполнения лабораторной работы.